

FixProof: A Validation-Oriented System for AI-Generated Vulnerability Remediation

Tony Tran

Progress Report 4 - Working Draft, September 30, 2026

Draft status: This is an early Report 4 checkpoint prepared after Progress Report 3 and Video III were posted. It records completed work through September 30. Peer feedback, a possible PATH-S06 rerun, the clean-package rehearsal, and the final effort total are not yet complete and are identified as planned work.

Problem Statement:

AI coding tools can produce insecure code, while a proposed security repair can leave a weakness exploitable or change intended application behavior. Disappearance of a static-analysis warning alone is incomplete evidence of a correct repair. Pearce et al. (2022) found approximately 40% of 1,689 Copilot-generated programs vulnerable within their selected security scenarios. Existing work also studies LLM vulnerability repair and validation feedback (Pearce et al., 2023; Kulsum et al., 2024). FixProof asks whether separately recorded static, runtime-security, functional, policy, and human-review evidence can reveal failed or behavior-changing patches that a SAST-only decision could classify as successful.

The evaluated scope remains deliberately narrow: three purpose-built JavaScript/Express applications with reflected XSS (CWE-79), SQL injection (CWE-89), and path traversal (CWE-22). FixProof evaluates repeated AI-generated repairs to these fixtures, not a representative corpus of applications or production repositories. The 15 scheduled model calls are five repairs per fixture, not 15 independent applications and not a production repair-success estimate.

The project translates beyond the benchmark through its evidence structure, not through the observed 5/15 SAST-resolution or 15/15 primary-suite values. For another repository, FixProof would need repository-specific build and start commands, scanner configuration, a target-finding mapping, security and benign behavior oracles, and a documented human-review criterion. The transferable part is the separation and preservation of these evidence channels and the rule that the repair model cannot approve its own candidate.

Solution Statement:

FixProof uses Python to orchestrate Semgrep CE scanning, finding normalization, focused remediation prompts, candidate application in a copied workspace, JavaScript syntax checks, SAST comparison, targeted security tests, and functional tests. Deterministic policy routes each candidate to REJECT, READY_FOR_HUMAN_REVIEW, or NEEDS_HUMAN_ADJUDICATION. The model receives a frozen finding and focused source context and proposes code, but it cannot run the scanner, application, browser, or tests and cannot approve or deploy the candidate. Human conclusions remain separate records.

The design choices are deliberate. Minimal fixtures provide reproducible vulnerability ground truth and benign-behavior expectations within the course timeline, at the cost of production realism. A fixed model, prompt template, tool setting, and five-call schedule hold generation conditions constant while showing within-fixture variation. They do not provide independent application samples or a model-to-model comparison. Semgrep provides a preserved static signal, while targeted runtime and functional checks measure exploit behavior and intended behavior separately. Copied workspaces preserve study inputs but are not security sandboxes. Deterministic policy makes evidence handling repeatable, and human review remains outside model authority.

Deliverables include the prototype, three versioned CWE fixtures, frozen primary-v1 evidence, separately registered supplemental-v1 evidence, original and later human records, a dashboard and CLI demonstration, reproducibility documentation, the sanitized public evidence reference, course videos, and the final report and presentation. The public website displays saved, sanitized evidence; it performs no model calls, scans, application execution, approval, or deployment.

Completed Tasks (Since Progress Report 3):

- Submitted Progress Report 3 on September 28, ahead of its October 4 course deadline. The submitted report preserved primary and supplemental denominators, separated original reviews from later qualifications, and directly addressed the professor's concern about translating a small benchmark to the stated problem.
- Finalized and revalidated the nine-slide Video III deck and narration. The scope slide now explains the three fixtures, controlled model setup, and separated roles in plain language. The deck states that five calls per fixture means 15 repeated repairs of three applications, not 15 independent applications.

- Corrected the workflow figure so the policy paths are unambiguous: all automated outcomes enter the primary record; selected cases branch to human review; the verdict and rationale return to the record; and primary evidence plus later supplemental outcomes inform a separate follow-up without rewriting primary-v1.
- Rechecked the saved evidence on September 30. Primary verification reports 15/15 initial attempts and 10/10 original conflict reviews complete. Supplemental verification reports three baselines and 15 saved candidates. The follow-up verifier reports 14/14 later human records complete.
- Posted Video III by September 30 and shared the sanitized evidence reference at <https://fixproof.netlify.app/>. The deployed reference presents 15 candidate records, the primary and supplemental summaries, preserved human decisions, patch excerpts, the workflow diagram, and the PDF appendix. It is a read-only presentation layer rather than a test runner.
- Prepared a bounded Progress Report 4 plan. The current feedback question asks whether confidence would improve more by testing another vulnerable application or by completing the path-traversal symlink case that Windows could not run.
- Preserved all experimental boundaries. No new model calls were made, no primary or supplemental-v1 result was overwritten, and no Linux PATH-S06 result is claimed in this draft.

Effort checkpoint: Personal hours since the September 28 Report 3 submission have not yet been reconciled. Before the October 18 submission, replace this sentence with actual dates, activities, and hours from the personal work log. Do not automatically extend the earlier 1.5-hours-per-day estimate unless it matches the time actually worked.

Remaining Work Before Progress Report 4 Submission:

- Retain the Video III submission receipt and complete Peer Feedback Report III by October 11. Summarize substantive feedback with a disposition of adopt, defer, or decline and a short reason. Peer comments inform project choices; they are not experimental observations.
- Decide whether to execute one bounded extension. The recommended default is PATH-S06 in Linux, WSL2, a Linux virtual machine, or another environment that can reliably create symbolic links. Adding a second fixture should be deferred unless there is enough time to define and freeze its benchmark and oracles before execution.
- Before any new run, create a dated test plan that fixes the environment, candidate set, input, expected baseline behavior, pass/fail/inconclusive rules, output paths, and stopping rule. Do not change these criteria after viewing candidate outcomes. Any corrected plan must receive a new version and explanation.
- If PATH-S06 is selected, preserve supplemental-v1 as originally recorded. Create an in-root symbolic link named link that points to the disposable outside directory, request link/outside-secret.txt, and apply the same case to the vulnerable baseline and all five saved traversal candidates. A candidate passes only when the outside marker is absent and the response is HTTP 400, 403, or 404. Disclosure is a failure. Environment or fixture inability remains inconclusive.
- Audit the existing control and failure-handling evidence: structured model response validation, canonical-finding identity checking, startup and request timeouts, recorded infrastructure failures, and the deterministic non-AI false-success control. Keep that control outside the 15 AI-attempt denominator.
- Perform a clean-package reproducibility rehearsal. Verify primary evidence, supplemental evidence, all human-record bindings, the public-reference export, and the documented commands from a clean copy that excludes local environments, caches, credentials, and disposable logs.
- Reconcile actual hours, update this draft with received feedback and any new separately versioned results, inspect the rendered DOCX/PDF, confirm the live Canvas instructions, and submit Progress Report 4 by October 18 at 11:59 p.m.

Tasks for the Next Project Report:

- Incorporate applicable Video III feedback and the completed Report 4 scope decision into the methods, limitations, and future-work sections.
- Post Video IV and complete its peer-feedback assignment according to the live Canvas schedule.
- Expand the source-checked related-work comparison across benchmark type, repair input, validation oracle, retry policy, success definition, and limitations. Keep research papers distinct from OWASP, CWE, and Semgrep technical references.
- Continue the final report using separate sections for primary-v1, pilot and non-AI controls, supplemental-v1, any later extension, and human review.
- Prepare a versioned release candidate and repeat the clean reproduction procedure before Progress Report 5.

Questions I Have or Issues I Am Running Into:

The immediate technical gap is PATH-S06. On Windows, symbolic-link creation failed with WinError 1314, so the baseline and all five traversal candidate observations remain inconclusive. The unexecuted Linux proposal is meant to close that environment gap, not to revise supplemental-v1. A lexical path.resolve containment check does not by itself establish that a symbolic link's filesystem target remains inside the allowed directory.

The design must also avoid overstating the small benchmark. One fixture per CWE, repeated calls, one distinct SQLi candidate source, targeted tests, and same-host verification restrict generalization. Completing PATH-S06 would close a known security uncertainty but would not add application diversity. A second fixture would improve breadth but require new ground truth, oracles, and a separate frozen protocol. Video III feedback will inform this tradeoff.

Feedback requested: Which next step would increase confidence more: testing FixProof on another vulnerable application, or completing the path-traversal test that Windows could not run? What specific evidence would you expect before considering the workflow reproducible by another student?

Methodology Paragraph Summary:

Each controlled fixture defines an attacker-controlled input, target route, vulnerable operation, synthetic data, baseline attack behavior, and benign-behavior expectations. The frozen primary protocol uses five separate initial repair calls per CWE. It holds the generator (gpt-5.2), prompt template (1.0), and model tool access (none) constant while withholding evaluator ground truth and test implementations from the repair prompt. The same saved candidates receive syntax, Semgrep, targeted HTTP/browser security, and functional checks. SAST-only interpretation and deterministic multistage policy are compared on those same candidates. Primary attempts, pilot retries, the non-AI false-success control, lifecycle replay, and supplemental tests retain separate denominators.

Default Semgrep CE auto did not identify the SQL-injection target. Primary-v1 preserved that default miss and used a labeled, benchmark-focused fixproof_controlled taint rule for repeatable before-and-after target comparison. SQLi ground truth remained independent of SAST and was established through the demonstrated runtime exploit. The five SQLi calls returned identical candidate source; this duplication is reported as an observed model outcome rather than five unique implementations.

Supplemental-v1 was fixed before candidate execution and compares each saved candidate with its baseline using separate security, behavioral-parity, and robustness oracles. It made no new model calls and did not rerun primary SAST. Inconclusive execution is not a pass. Later human decisions qualify the result without changing registered outcomes, original reviews, or primary metrics. OWASP WSTG and Semgrep's run-rules documentation serve as technical references for runtime-test organization and scanner configuration.

Pearce et al. (2022) motivate treating generated code as untrusted. Pearce et al. (2023) examine zero-shot vulnerability repair and functional-correctness challenges. Kulsum et al. (2024) study repair with external compiler, sanitizer, and test feedback. FixProof does not claim that validation feedback is new. Its bounded contribution is the auditable combination of separately preserved static, runtime-security, functional, policy, and human evidence for three Express weaknesses. Different datasets and success definitions prevent direct comparison of success rates.

Timeline:

When	Description of Task	Status
September 28	Submit Progress Report 3; official deadline October 4	Completed
September 29	Finalize and validate Video III deck, script, workflow, and Q&A backup	Completed
By September 30	Post Video III and share the sanitized evidence reference	Completed
October 1-11	Collect Video III feedback and complete Peer Feedback Report III	In progress / planned
October 8-12	Audit control and failure-handling evidence; make the dated extension decision	Planned
October 12-15	If selected, execute PATH-S06 under a frozen, separate symlink-capable protocol; otherwise complete reproduction rehearsal	Planned
October 15-17	Reconcile hours, update limitations and references, render and inspect Report 4	Planned
October 18	Confirm Canvas instructions and submit Progress Report 4 by 11:59 p.m.	Planned
October 20 / 25	Post Video IV and complete Peer Feedback Report IV	Planned; confirm live Canvas

When	Description of Task	Status
November 1 / 3 / 8	Progress Report 5, Video V, and peer feedback	Planned; confirm live Canvas
November 15	Submit final presentation video, no more than 15 minutes	Planned
November 22	Submit peer feedback on final presentation	Planned
December 6	Submit final project report and reproducible package	Planned

Evaluation:

The experimental results are unchanged as of September 30. All 15 frozen primary initial attempts have complete evidence. The denominator excludes pilot retries and the deterministic non-AI control. Original human conflict reviews are 10/10 complete: seven acceptances under the original evidence and three requests for more testing. Later decisions are recorded separately.

Primary case	Initial attempts	Target SAST resolved	Security pass	Functional pass	Automated decision
Reflected XSS	5	0/5	5/5	5/5	5 need adjudication
SQL injection	5	5/5	5/5	5/5	5 ready for review
Path traversal	5	0/5	5/5	5/5	5 need adjudication
Total	15	5/15	15/15	15/15	5 ready for review; 10 need adjudication

Security and functional columns count candidates whose entire frozen primary suite passed; they do not count individual cases. Target-SAST resolution was 5/15 (33.3%), and SAST/runtime disagreement was 10/15 (66.7%). The XSS and traversal findings remained for all ten candidates even though their registered primary runtime suites passed. These are evidence disagreements, not proof that the findings are false positives or that the patches are fully secure. No primary SAST false success was observed; a separate labeled non-AI control exercises that policy branch without entering AI-attempt metrics.

Supplemental category	Observations	Pass	Fail	Inconclusive	Meaning
Security	60	55	0	5	PATH-S06 could not create its Windows symlink fixture for five traversal candidates
Behavioral parity	45	40	5	0	Four XSS missing-input changes and one traversal valid-file rejection
Robustness	35	25	10	0	New SQLi and traversal ambiguous/malformed-input contracts
Total	140	120	15	5	Mixed categories; not one security success rate

The supplement evaluated the same 15 saved candidates after baseline characterization. XSS 03 passed all nine registered supplemental cases. XSS 01, 02, 04, and 05 passed their three registered security cases but failed the frozen XSS-P01 missing-input parity case; later records reject those four candidates under exact parity. The rejections do not mean the registered XSS attacks remained exploitable.

All five SQLi candidates passed three supplemental injection-security and two behavioral-parity cases and returned no unauthorized rows. SQL-R01 still failed because repeated username parameters returned HTTP 200 with an empty array rather than the registered HTTP 400 response. The five later acceptances are bounded to the tested injection repair and preserve this disclosed robustness failure.

Every traversal candidate passed the five executable supplemental security cases, but PATH-S06 remained inconclusive. Traversal 01 also failed one parity and one robustness case and was later rejected. Traversal 02-05 received later requests for more testing; traversal 03 retains three robustness failures and traversal 05 retains the repeated-parameter failure. There are 14 later human records in total: five rejections, five bounded SQLi acceptances, and four requests for more testing. No later record overwrites a primary result.

Report 4 extension status	Current state on September 30
Video III feedback	Video posted; feedback collection and disposition summary pending

Report 4 extension status	Current state on September 30
PATH-S06 symlink-capable rerun	Not executed; original five inconclusive observations remain authoritative for supplemental-v1
Second fixture	Not selected or executed
Primary-v1 metrics	Frozen and unchanged
Supplemental-v1 metrics	Frozen and unchanged
Clean-package rehearsal	Planned before Report 4/final delivery

Report Outline:

1. Problem, motivation, and bounded research question.
2. Related work, alternatives, and specific contribution.
3. Controlled scope, threat model, and benchmark construction.
4. Architecture, model authority, validators, deterministic policy, and human boundary.
5. Frozen primary method, comparator, provenance, and reproducibility.
6. Primary results, separate pilot/control examples, and original human reviews.
7. Supplemental methods and results, later human qualifications, and any separately versioned extension.
8. Generalization boundary, limitations, deployment feasibility, and lessons from peer feedback.
9. Conclusion, references, evidence index, and AI-use disclosure.

References:

Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., & Karri, R. (2022). Asleep at the keyboard? Assessing the security of GitHub Copilot's code contributions. 2022 IEEE Symposium on Security and Privacy. <https://doi.org/10.1109/SP46214.2022.9833571>

Pearce, H., Tan, B., Ahmad, B., Karri, R., & Dolan-Gavitt, B. (2023). Examining zero-shot vulnerability repair with large language models. 2023 IEEE Symposium on Security and Privacy. <https://doi.org/10.1109/SP46215.2023.10179324>

Kulsum, U., Zhu, H., Xu, B., & d'Amorim, M. (2024). A case study of LLM for automated vulnerability repair: Assessing impact of reasoning and patch validation feedback. Proceedings of the 1st ACM International Conference on AI-Powered Software. <https://doi.org/10.1145/3664646.3664770>

OWASP Foundation. (n.d.). Web Security Testing Guide, version 4.2. <https://wstg.owasp.org/v4.2/>

Semgrep. (n.d.). Run rules. <https://semgrep.dev/docs/running-rules>

Appendix:

Evidence index: docs/study-protocol-v1.md and benchmarks/primary/v1/ define the frozen primary study. data/primary_trials/v1/, data/primary_reviews/v1/, and data/evaluation/primary-report.json preserve candidate, automated, and original human evidence. docs/supplemental-protocol-v1.md, tests/supplemental/v1/cases.json, data/supplemental/v1/, and docs/supplemental-results-v1.md preserve the supplemental protocol, cases, observations, and 14 later records. fixproof-public/ contains the sanitized static reference deployed at <https://fixproof.netlify.app/>. The Video III deck, script, render, validation record, and Report 4 plan are under docs/coursework/review-2026-09-29/.

Verification checkpoint, September 30: primary evidence verified 15/15 initial attempts and 10/10 original reviews; supplemental evidence verified three baselines and 15 saved candidates; supplemental human records verified 14/14 complete. The deployed public JSON reported 15 candidates, 140 supplemental candidate-case observations, and 14 later human records. These checks verify saved evidence and bindings; they do not rerun model calls or turn targeted tests into a production-security claim.

Generative AI disclosure: OpenAI ChatGPT/Codex assisted planning, implementation, debugging, test orchestration, documentation, evidence organization, presentation preparation, and drafting. FixProof separately used saved OpenAI API calls to generate the primary repair candidates. Tony Tran remains responsible for verifying claims and references, reporting actual effort, making human-review decisions, approving any new test plan, and approving the submitted text.